SIMATS ENGINEERING ASSESSMENT

TOOL 3

COURSE NAME: Ethical Hacking
COURSE CODE: ITA14

COURSE OUTCOME
COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks. (BT4)

Assessment Tool Weightage:

30% Duration: 90 minTotal

Marks: 50

Code of Conduct:

I A GUNA SEKAR (192525302) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: A GUNA SEKAR

Scenario-Based Assessment

Topic 1: Footprinting Tools – Conducting Competitive Intelligence Q1. (L3 – Apply) – 15 Marks

A cybersecurity consultant has been assigned to perform a passive security assessment for a company named ABC Technologies. The consultant must collect publicly available information without directly interacting with the company’s servers.

Task: Apply suitable footprinting tools to identify the company’s:
o domain registration details, o employee email addresses, o technology stack, o and publicly exposed subdomains. Explain how each selected tool helps in conducting competitive intelligence.

1. Aim

To conduct a passive footprinting assessment of ABC Technologies by collecting publicly available information about its domain registration, employee email addresses, technology stack and exposed subdomains, without directly interacting with the company's servers.

2. Introduction

Footprinting is the first phase of ethical hacking, in which as much information as possible is collected about a target organisation. In passive footprinting the information is taken only from public sources such as WHOIS databases, search engines, certificate transparency logs and public DNS datasets. No packets are sent to the company's servers, so the activity cannot be detected by it. The same information also gives competitive intelligence about the organisation.

3. Tools and their applications

Tool Information collected Purpose

WHOIS Domain registrar, registration
and expiry dates, name servers and registrant details when public
Understand domain ownership and registration history

theHarvester Publicly indexed email
addresses, employee names, hosts and subdomains
Identify publicly visible organisational information Wappalyzer / BuiltWith
Website technologies, frameworks, CMS, web server and analytics tools
Understand the publicly observable technology stack

DNS DNSDumpste
records, subdomains and r / crt.sh
related infrastructure from public data and certificate logs
Map the organisation's external digital footprint

Search engines
Public employee profiles, company pages, job postings and indexed documents
Gather publicly available competitive intelligence

4. Procedure

Step 1: Collect domain registration details using WHOIS

```
whois example.com
```

Replace example.com with the authorised assessment domain. Review the registrar, creation and expiration dates, name servers and the publicly available registrant information.

Step 2: Find publicly indexed emails using theHarvester

```
theHarvester -d example.com -b duckduckgo -l 100
```

This searches a public source for emails, names and hosts associated with the domain. The data source may vary depending on the installed version.

Step 3: Identify the technology stack

Use the Wappalyzer browser extension or the BuiltWith website lookup. Record the publicly observable technologies such as the CMS, JavaScript frameworks, analytics services and web server.

Step 4: Discover publicly exposed subdomains

Use DNSDumpster or search the certificate transparency log at crt.sh with the query %.example.com. Both sources are public, so the company's servers are not contacted. Names such as mail.example.com or portal.example.com are only examples, not confirmed findings.

5. How the tools support competitive intelligence

• WHOIS: Helps understand domain registration, registrar relationships, hosting dependence and how the infrastructure is administered.

• theHarvester: Helps identify public contact information, the email naming pattern and the people or departments visible to outsiders.

• Wappalyzer / BuiltWith: Reveals technologies that indicate the company's technical capabilities, software ecosystem and investments.

• DNSDumpster / crt.sh: Helps map publicly documented infrastructure and identify internet-facing services, including test or new product sites.

• Search engines: Help discover public announcements, job postings, technical documents and other organisational information.

6. Security risks and precautions

The collected information can be misused for targeted phishing, employee impersonation, technology-specific attacks and infrastructure reconnaissance. ABC Technologies should minimise unnecessary public disclosure, configure SPF, DKIM and DMARC, keep its web technologies updated, review its DNS records regularly, and train employees to recognise social engineering attacks.

Conclusion

Passive footprinting tools give valuable competitive intelligence without probing the company's servers, and help recommend improvements to its security posture.

Topic 2: DNS Zone

Transfers Q2. (L3 – Apply)

– 15 Marks

During an authorized penetration test, a security analyst suspects that the target organization’s DNS server is misconfigured and may allow unauthorized DNS zone transfers.

Task: Apply the appropriate DNS command or tool to verify whether zone transfers are permitted. If the transfer succeeds, explain how the retrieved DNS records can be used to identify internal hosts, mail servers, and subdomains during reconnaissance.

1. Aim

To verify whether an authorised target DNS server permits DNS zone transfers and to explain how the resulting records may assist reconnaissance.

2. Introduction

A DNS zone transfer (AXFR) is the method used by a primary DNS server to copy the complete zone file to its secondary servers. When a server is misconfigured and accepts transfer requests from any host, anyone can download every record of the domain with a single query. This is an information disclosure weakness. The test is carried out only with written permission from the organisation.

3. Tools required

- dig command-line DNS utility (other options: host, nslookup, dnsrecon, nmap)
- Kali Linux terminal
- An authorised target domain and its authoritative DNS server

4. Procedure

Step 1: Identify the authoritative name servers

```
dig NS example.com
```

This command lists the name servers associated with the domain.

Step 2: Identify the target DNS server

Select an authoritative name server from the returned records, for example ns1.example.com. Every listed name server should be tested, because one secondary server may be configured differently from the others.

Step 3: Test whether a zone transfer is permitted

```
dig AXFR example.com @ns1.example.com
```

Replace example.com and ns1.example.com with the authorised test domain and its actual authoritative server. Other commands that perform the same test are:

```
host -l example.com ns1.example.com dnsrecon -d
example.com -t axfr
```

Step 4: Analyse the result

• Transfer succeeds: The output contains a series of DNS records from the requested zone, starting and ending with the SOA record.
• Transfer fails or is refused: The message "Transfer failed" or "REFUSED" is shown. The server is probably restricting transfers correctly, although network restrictions and server configuration can also affect the result.

A successful transfer should be compared with the organisation's intended DNS configuration, because some zones are deliberately published to approved secondary DNS servers.

1. Analysis of retrieved DNS records

DNS record	Purpose	Reconnaissance value
A	Maps a hostname to an IPv4 address	Helps identify internal hosts such as intranet, fileserver or db01 and their IP addresses
AAAA	Maps a hostname to an IPv6 address	Reveals IPv6-enabled infrastructure
MX	Identifies mail exchangers	Reveals the mail servers and whether a third-party mail service is used

NS Identifies authoritative
name servers
Helps map the DNS infrastructure
CNAME Identifies hostname
aliases
Shows subdomains such as dev, vpn or
portal and relationships between services TXT Contains text-based
DNS information
May expose email security policies (SPF) or other published configuration data SRV
Identifies service
locations
May reveal services such as LDAP, Kerberos or SIP
2. Use during reconnaissance
• Internal hosts: A and AAAA records list hostnames and IP addresses, which shows the naming convention and the address ranges in use.
• Mail servers: MX records give the mail server names and priority, which helps in planning email-related security testing.
• Subdomains: Records for names such as dev, staging, vpn and admin show hidden or forgotten services that are often less protected.

The tester then uses this list to choose the IP ranges and hosts for the next phase, such as port scanning and service enumeration, always within the authorised scope.

3. Security implications

If an unauthorised zone transfer succeeds, an attacker may obtain hostnames, mail server names, subdomains and other DNS records. This makes it easier to map the infrastructure of the organisation, identify potentially exposed services and create convincing phishing messages. A successful zone transfer does not, by itself, grant access to the systems identified in the records.

4. Countermeasures

1. Restrict AXFR requests to authorised secondary DNS servers.
2. Configure access control lists (ACLs) for approved server IP addresses (allow-transfer in BIND).
3. Use TSIG authentication for zone transfers where supported.
4. Separate internal DNS zones from externally published DNS information (split-

horizon DNS).

5. Remove obsolete and unnecessary DNS records.
6. Monitor DNS logs for unexpected transfer requests.
7. Conduct regular authorised DNS configuration reviews.

Conclusion

The dig AXFR command helps verify whether a DNS server permits zone transfers. Unauthorised transfers can disclose valuable infrastructure information. Restricting transfers, authenticating authorised servers and monitoring DNS activity reduce the risk of information disclosure.

Topic 3: Introduction to Social Engineering – Social Engineering Attacks and Countermeasures

Q3. (L3 – Apply) – 20 Marks

Employees of an organization receive an email claiming to be from the IT department, asking them to verify their login credentials through a provided link because of an urgent security update.

Task: Identify the type of social engineering attack and apply suitable countermeasures that employees should follow before responding to the email. Explain how these actions help prevent credential theft.

1. Identification of the attack

The scenario describes a phishing attack, specifically an email-based credential-harvesting attempt. Because the message is aimed at the employees of one organisation and imitates its internal IT department, it can also be called spear phishing.

The email pretends to originate from the IT department and creates urgency by claiming that employees must verify their credentials because of a security update. The objective is to persuade employees to visit a fraudulent link and disclose their login information.

2. Social engineering techniques used

- Impersonation: The attacker pretends to be a trusted IT employee.
- Pretexting: A false story, the urgent security update, is used to make the request look genuine.
- Urgency: The alleged update pressures employees to act quickly without thinking.
- Fear: The message may imply that an account will be blocked or become insecure.
- Deceptive links: The supplied link may lead to a fake login page that looks like the real one.
- Credential harvesting: The attacker attempts to collect usernames and passwords.

3. Warning signs of the email

- The sender address or domain is slightly different from the real company domain.
- The language is urgent or threatening, for example "verify within 30 minutes".
- The message contains a generic greeting, spelling mistakes or an unexpected link.
- It asks for a password, which a genuine IT department does not request through email.

4. Countermeasures employees should follow

1. Verify the sender Check the full sender address and domain. A familiar display name does not guarantee that the email is legitimate.
2. Inspect the link Check the actual destination by hovering over it before opening it. Do not enter credentials into a website reached through an unexpected email.
3. Verify through an independent channel Contact IT support using a known phone number, the official service desk or the bookmarked company portal, rather than replying to the suspicious email.
4. Never disclose passwords Legitimate IT staff do not ask employees to submit their passwords through an email link. Use the organisation's official password-management or account- recovery process.
5. Report the email Use the company's phishing-reporting button or notify the security

team. Avoid forwarding the email to other employees unnecessarily.

1. Organisational security measures

Security measure How it helps

Multi-factor authentication (MFA)

Adds another authentication layer if a password is stolen; phishing-resistant MFA provides stronger protection. Email filtering Detects and blocks suspicious messages, malicious

links and attachments.

SPF, DKIM and DMARC Help reduce email spoofing of the organisation's domain. Security awareness training

Teaches employees to identify phishing indicators and report suspicious messages; simulated phishing tests measure progress.

URL protection Blocks known phishing websites and suspicious destinations. Incident response procedures

Enable quick account protection, investigation and containment after a suspected compromise.

2. What should an employee do if credentials have already been entered?

1. Report the incident to IT or the security team immediately.
2. Change the compromised password through the official website using a trusted device.
3. Revoke active sessions and reset affected authentication methods if instructed by the security team.
4. If the same password was reused elsewhere, change it on those accounts too.
5. Follow the organisation's incident-response instructions and keep the suspicious email for investigation.

3. How these actions prevent credential theft

Sender verification helps identify impersonation. Link inspection reduces the likelihood of visiting fraudulent websites. Independent verification confirms whether the request is genuine. Refusing to disclose passwords prevents attackers from obtaining credentials, while MFA reduces the impact of passwords that are stolen. Reporting suspicious messages also helps the security team block similar attacks against other employees.

Conclusion

The scenario is an email phishing attack that uses urgency and IT impersonation to steal login credentials. Social engineering targets people rather than systems, so employee awareness is the strongest defence. When employees verify the sender,

avoid the link, confirm the request through a trusted channel, use MFA and report the message, the attacker cannot obtain the credentials and the attempt fails.